Privacidad y manejo de datos — BlockBridge Academy v2

Versión	2.0 (sustituye a `PRIVACY_POLICY.md` v0.1 de la v1)
Fecha	29 de octubre de 2026
Marco de referencia	Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP, DOF 20-03-2025)

> Este documento describe lo que el sistema hace realmente; **no es asesoría legal**. Se escribió para un proyecto académico: si el sistema atiende a personas reales, debe nombrar a su responsable, con domicilio y contacto.
>
> - Si lo opera **una persona física o una empresa**, aplica la LFPDPPP y la autoridad es la Secretaría Anticorrupción y Buen Gobierno.
> - Si lo opera **la universidad** (institución pública), aplican la Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados y la ley estatal correspondiente. En ese caso cambian el formato del aviso y la autoridad garante.
>
> Hay que verificar la vigencia de las leyes y los plazos citados al momento de publicar.

Contenido:

- **Parte A.** Aviso de privacidad integral (público, en `privacidad.html`).
- **Parte B.** Aviso de privacidad simplificado (formulario de registro).
- **Parte C.** Política interna de manejo de datos e información sensible (para el equipo y el DBA).

Parte A. Aviso de privacidad integral

Última actualización: 4 de noviembre de 2026 · **Versión del aviso:** 2.0

1. Responsable

BlockBridge Academy es un proyecto académico. Quien lo desarrolla y administra es responsable del tratamiento de tus datos personales.

2. Datos personales que tratamos

Si usas el sistema…	Datos	De dónde vienen
Como **invitado**	Un identificador aleatorio y tus resultados en los quizzes	Los genera el sistema; **no pedimos ningún dato que te identifique**
Con **cuenta**	Apodo, correo electrónico y contraseña; tus resultados (puntajes, intentos, pistas usadas y tiempos); la versión y fecha en que aceptaste este aviso	Tú nos los das al registrarte; los resultados los genera tu uso
Como **docente**	Lo anterior, más los ejercicios y quizzes que creas	Tú nos los das

Tu contraseña la guarda nuestro proveedor de autenticación (Firebase) en forma cifrada; nunca la vemos.

No tratamos datos personales sensibles (origen étnico o racial, estado de salud, información genética, creencias religiosas, filosóficas o morales, opiniones políticas, preferencia sexual, afiliación sindical). Tampoco pedimos nombre real, fecha de nacimiento, teléfono, domicilio, fotografía ni datos financieros.

Te pedimos que tu **apodo no sea tu nombre real**.

3. Para qué usamos tus datos

Finalidades necesarias (sin ellas no podemos darte el servicio):

1. Crear y administrar tu cuenta y autenticarte.
2. Calificar tus respuestas, calcular tu puntaje y mostrarte tu historial.
3. Mostrar a los docentes los resultados de sus quizzes **con tu apodo, nunca con tu correo**.
4. Enviarte correos de verificación y de recuperación de contraseña.
5. Proteger el sistema contra abusos y cumplir obligaciones legales.

Finalidades secundarias: ninguna. No usamos tus datos para publicidad, mercadotecnia, perfilamiento ni para entrenar modelos de inteligencia artificial, y no los vendemos.

Podemos publicar **estadísticas agregadas y anónimas** (por ejemplo, «el promedio del quiz de ciclos fue 72») en reportes académicos. Esas estadísticas no te identifican y por eso no son datos personales.

4. Con quién compartimos tus datos

No transferimos tus datos a terceros. Para operar usamos proveedores que los tratan **por nuestra cuenta y bajo nuestras instrucciones** (encargados). Estas comunicaciones no requieren tu consentimiento:

Proveedor	Servicio	Ubicación
Google LLC (Firebase)	Autenticación y base de datos	Estados Unidos
Google LLC (reCAPTCHA)	Detectar uso automatizado a partir de datos técnicos del navegador	Estados Unidos
Vercel Inc.	Hospedaje del sitio y del servicio de calificación	Estados Unidos y red global

Solo comunicaríamos tus datos a una autoridad que lo requiera conforme a la ley.

5. Menores de edad

Si eres menor de 18 años, puedes usar el **modo invitado**, que no pide datos personales. Para crear una cuenta necesitas la **autorización de tu madre, padre o tutor**, y al registrarte declaras contar con ella. Si detectamos una cuenta de un menor sin autorización, la eliminaremos.

6. Cuánto tiempo conservamos tus datos

Dato	Plazo
Resultados de invitados	30 días; después se borran automáticamente
Cuenta y resultados	Mientras tengas la cuenta. Si no la usas en 12 meses, la eliminamos
Copias de seguridad	Hasta 4 semanas después de borrar un dato

7. Tus derechos ARCO y cómo ejercerlos

Tienes derecho a **Acceder** a tus datos, **Rectificarlos**, **Cancelarlos** (eliminarlos) y **Oponerte** a su tratamiento. También puedes **revocar tu consentimiento**.

Por ti mismo, al momento, en «Mi cuenta»:

- Descargar todos tus datos (acceso).
- Cambiar tu apodo (rectificación).
- Eliminar tu cuenta y todos tus datos (cancelación y revocación).

8. Cookies y tecnologías de rastreo

No usamos cookies de publicidad, analítica de terceros ni píxeles de rastreo. reCAPTCHA, de Google, usa sus propias cookies para distinguir personas de programas automatizados.

Para mantener tu sesión abierta, el sistema guarda en tu navegador (almacenamiento local) el identificador de sesión de Firebase. También guarda una copia del ejercicio que estás resolviendo, para no perderlo si recargas la página. Las dos cosas son estrictamente necesarias y se borran al cerrar sesión.

9. Seguridad

Usamos conexiones cifradas (HTTPS), reglas de acceso en la base de datos que niegan todo lo que no está expresamente permitido, y un servicio de calificación separado del navegador. Nadie, ni siquiera un docente, puede ver tu correo. Ver la Parte C.

10. Cambios a este aviso

Publicaremos cualquier cambio en esta página con su fecha y número de versión. Si el cambio es relevante, te pediremos aceptar el nuevo aviso la próxima vez que inicies sesión.

11. Autoridad

Si consideras que tu derecho a la protección de datos fue vulnerado, puedes acudir a la autoridad de protección de datos competente.

Parte B. Aviso de privacidad simplificado

> Se muestra en el formulario de registro, encima de las casillas de aceptación.

BlockBridge Academy usará tu **apodo, correo y resultados** solo para darte acceso, calificar tus quizzes y mostrar tus resultados a tus docentes **con tu apodo, nunca con tu correo**. No los usamos para publicidad ni los vendemos. Nuestros proveedores Google (Firebase) y Vercel los almacenan en Estados Unidos. Puedes descargar o eliminar tus datos en cualquier momento desde «Mi cuenta». Consulta el aviso completo en Aviso de privacidad.

☐ He leído y acepto el aviso de privacidad. ☐ Soy mayor de edad o cuento con autorización de mi madre, padre o tutor.

Parte C. Política interna de manejo de datos e información sensible

Aplica al desarrollador, al DBA y a cualquier persona con acceso al código, a la Consola de Firebase o al panel de Vercel.

C.1 Principios

1. **Minimización:** no se recaba un dato si ninguna funcionalidad del MVP lo necesita. Agregar un campo personal requiere actualizar este documento y el aviso.
2. **Privacidad por diseño:** la protección vive en las Security Rules y en el servidor, no en la interfaz. Ocultar un botón no cuenta como control de acceso.
3. **Mínimo privilegio:** cada actor accede solo a lo que necesita (matriz en el doc. 04 §5).
4. **Sin puertas traseras:** no hay cuentas maestras, contraseñas embebidas, endpoints ocultos ni modos *debug* en producción.

C.2 Clasificación de la información

Nivel	Qué incluye	Dónde vive	Controles
Pública	Enunciados y quizzes publicados, catálogo de bloques, avisos	`ejercicios`, `quizzes`, sitio	Lectura según las reglas; solo el autor la modifica
Confidencial: datos personales	Apodo, correo, resultados, aceptación del aviso	Firebase Auth, `usuarios`, `sesiones`	Reglas por `uid`; el docente solo ve apodos; borrado al eliminar la cuenta; TTL para invitados
Confidencial: integridad académica	Soluciones, pistas no reveladas y explicaciones	`ejercicios/{id}/privado/clave`	Solo el autor y el servidor; nunca se envían al estudiante antes de tiempo
Restringida	Clave de la cuenta de servicio, cuentas de la Consola de Firebase y de Vercel, respaldos	Variables de entorno de Vercel; gestor de contraseñas del DBA	2FA obligatorio; nunca en el repositorio ni en chats; rotación semestral o inmediata ante sospecha

C.3 Reglas para el código

Regla	Verificación
Ningún secreto en el repositorio: `.env*`, `*serviceAccount*.json` y `*.pem` están en `.gitignore`	`git grep -iE "private_key|BEGIN PRIVATE"` sin resultados antes de cada despliegue
La configuración pública de Firebase (`apiKey`, `projectId`) **sí** puede estar en el cliente; la seguridad la dan las reglas	Revisión de código
Las funciones no registran en logs tokens, correos, workspaces ni cuerpos de petición; solo `uid`, ruta, código de respuesta y duración	Revisión de `console.log` en `api/`

Regla	Verificación
Todo texto de usuario o docente se muestra con `textContent`	`grep -n innerHTML js/` revisado
Las reglas de Firestore se despliegan solo después de pasar las pruebas del emulador	Script de despliegue
Las versiones de CDN son exactas	Revisión de `<script>`

C.4 Acceso administrativo (DBA)

1. Las cuentas de la Consola de Firebase y de Vercel tienen **2FA** y son personales: nunca se comparten.
2. En el MVP el único propietario del proyecto es el DBA. Si se suma otra persona, recibe el rol IAM mínimo necesario, nunca *Owner*.
3. **Cambios de rol** (CU-15): solo con una solicitud por canal institucional; cada cambio se anota en la bitácora (fecha, `uid`, solicitante, verificación, quién lo hizo). La bitácora se conserva 2 años.
4. El DBA **no consulta datos personales** fuera de una necesidad concreta (solicitud ARCO, incidente, soporte pedido por el usuario), y lo anota en la bitácora.
5. Los datos de producción no se copian a entornos de desarrollo: para desarrollo y pruebas se usan el emulador y alumnos ficticios.

C.5 Retención y borrado

Dato	Plazo	Mecanismo	Estado
Sesiones de invitados	30 días	`GET /api/limpieza`, a diario, sobre `expiraEn`. La política TTL de `firestore.indexes.json` es opcional: exige facturación activa (plan Blaze)	MVP
Contador `limites/{uid}` del tope de sesiones (20 por hora)	Hasta borrar al usuario	`eliminarUsuario`; solo lo lee y escribe el servidor	MVP
Usuarios anónimos en Auth	30 días sin actividad	`GET /api/limpieza`, ejecutada a diario por Vercel Cron	MVP
Cuenta registrada eliminada por el usuario	Inmediato	`DELETE /api/cuenta`	MVP
Cuentas inactivas por 12 meses	12 meses	`GET /api/limpieza` (misma rutina que eliminar la cuenta), a diario	MVP
Respaldos	4 semanas	Exportación semanal a JSON cifrada (`age` o `gpg`), guardada por el DBA	MVP
Bitácora de cambios de rol y accesos	2 años	Documento del DBA	MVP
Logs de Vercel	Según el plan	Automático; sin datos personales (C.3)	MVP

Cuando un usuario elimina su cuenta, sus datos pueden seguir en los respaldos hasta 4 semanas. Si hubiera que restaurar un respaldo, antes se reaplican las eliminaciones registradas.

C.6 Atención de derechos ARCO

1. Se recibe la solicitud y se registra con la fecha.
2. Se verifica la identidad: la solicitud debe venir del correo registrado, o se envía un código a ese correo.
3. Se resuelve:
   - **Acceso:** se envía el JSON de exportación.
   - **Rectificación:** el apodo se cambia; el correo se cambia desde Firebase Auth.
   - **Cancelación:** se ejecuta la misma rutina que `DELETE /api/cuenta`.
   - **Oposición:** se cancela la cuenta, porque no hay finalidades secundarias de las que excluir.
4. Se responde en un máximo de 20 días hábiles y se hace efectiva en 15 días hábiles.

C.7 Respuesta a incidentes de seguridad

Fase	Acciones
1. Detectar	Alertas de presupuesto y uso de Firebase; errores anómalos en Vercel; reportes de usuarios
2. Contener	Revocar la clave de la cuenta de servicio y generar otra; desplegar reglas que bloqueen escrituras; revocar sesiones (`revokeRefreshTokens`); suspender cuentas implicadas
3. Evaluar	Qué datos, de cuántas personas, desde cuándo y por qué vía; se documenta en la bitácora
4. Notificar	Si el incidente afecta de forma significativa los derechos de las personas, se les informa **sin dilación**: qué pasó, qué datos se vieron afectados, qué hicimos y qué pueden hacer ellas. Se informa también a la autoridad cuando la ley lo exija
5. Corregir y aprender	Corregir la causa raíz, añadir una prueba o regla que la cubra y actualizar este documento

C.8 Revisión

Este documento se revisa al cerrar cada iteración y siempre que cambien los datos que se recaban, los proveedores o la ley. Cada cambio en el aviso público incrementa `avisoVersion` y obliga a volver a aceptarlo.

Pendientes antes de publicar

- [ ] Si el sistema atiende a personas reales: revisión legal y definición del responsable, con domicilio y contacto.
- [ ] Confirmar la región de Firestore elegida al crear el proyecto.
- [x] Términos de uso de la v2 publicados en `terminos.html`.
- [ ] Publicar una versión en lenguaje sencillo para estudiantes jóvenes.